Official Security Audit Remediation & Closure Report

Muttaka (Coworking Pass Platform)

Student: Anas Saeed Alghamdi | ID: 444005852
Umm Al-Qura University

Audit reference: Penetration Test Report by Tala Sami Alnabati, 28 October – 3 November 2026
Supplemental reference: Coworking Pass Confirmed Findings, pages 1–3
Report date: 9 November 2026

1 Executive Summary

The ten reported vulnerabilities have code-level remediations supported by the automated tests and static checks recorded below. The status describes local implementation evidence. Production closure remains subject to database migration, live PostgreSQL concurrency testing, browser verification and deployment approval.

Finding	Severity	Code status
F-01	Critical	RESOLVED & VERIFIED locally
F-02	Critical	RESOLVED & VERIFIED locally
F-03	Critical	RESOLVED & VERIFIED locally
F-04	Critical	RESOLVED & VERIFIED locally
F-05	Medium	RESOLVED & VERIFIED locally
F-06	Medium	RESOLVED & VERIFIED locally
F-07	Critical	RESOLVED & VERIFIED locally
F-08	High	RESOLVED & VERIFIED locally
F-09	High	RESOLVED & VERIFIED locally
F-10	High	RESOLVED & VERIFIED locally

2 Detailed Findings

F-01 Administrator Role Forgery — Critical

Root cause and exploit vector. A default JWT secret allowed an attacker to alter a B2C token role to SUPER_ADMIN, sign it with change-me and call GET /api/stats.

Applied code fix. backend/lib/auth/secrets.ts, verify-token.ts, sessions.ts and instrumentation.ts validate the signing key at startup, reject default or short values and restrict verification to HS256. Production development seed credentials are disabled; Super Admin passwords require at least 12 characters and four character classes.

Verification. security-input.test.ts and super-admin.test.ts cover weak keys, password rules and production seed planning.

F-02 Unbacked Wallet Deposit — Critical

Root cause and exploit vector. A standard bearer token could submit POST /api/wallet with {"userId":"dda8e4d6-...","amount":5000,"type":"DEPOSIT","description":"test deposit"}, creating funds without a gateway receipt.

Applied code fix. backend/app/api/wallet/route.ts restricts wallet mutations to SUPER_ADMIN. Customer checkout uses server-side wallet settlement; company deposits are likewise restricted.

Verification. security-checkout.test.ts covers debit and insufficient balance; the code-level role restriction is verified by inspection. A dedicated route-level deposit test is not included.

F-03 Fake Payment and Refund Chain — Critical

Root cause and exploit vector. The report describes a free direct booking, POST /api/payments with {"amount":7777,"method":"VISA","referenceId":"6bc1807a-..."}, then POST /api/refund to obtain 7,777 SAR.

Applied code fix. backend/app/api/payments/route.ts returns existing settlements instead of accepting asserted success; booking routes derive prices from database records. backend/lib/security/idempotency.ts and checkout.ts bind the booking, wallet debit and payment to a transaction. Refunds require an owner-bound WALLET settlement.

Verification. security-pricing, security-idempotency, security-checkout and security-refund tests cover tampered pricing, replay and unpaid-booking rejection.

F-04 Subscription Refund Fallback — Critical

Root cause and exploit vector. The previous expression originalPayment?.amount ?? subscription.plan?.price ?? 0 credited the 15,000 SAR catalog price for an unpaid subscription.

Applied code fix. backend/app/api/refund/route.ts requires a successful, owner-bound subscription WALLET payment and rejects missing payment; the catalog fallback is removed. Subscription DELETE uses the same refund path.

Verification. security-refund.test.ts checks rejection of the 15,000 SAR unpaid subscription and confirms no refund transaction starts.

F-05 Negative Payment Amount Acceptance — Medium

Root cause and exploit vector. The report submitted -500 SAR to POST /api/mock-payment; a truthiness check accepted the negative value.

Applied code fix. backend/lib/security/input.ts validates raw numeric tokens and finite numeric amounts from 1.00 to 100,000.00 SAR before rounding. The production mock route returns 404; non-production simulation does not create ledger entries. A migration adds non-negative finite ledger checks.

Verification. security-input.test.ts tests negative, zero, null, numeric strings, NaN, infinity, boundary values and exponent notation. security-idempotency.test.ts checks production mock denial.

F-06 Login OTP Verification Flooding — Medium

Root cause and exploit vector. The original assessment sent eight login requests in 1.1 seconds; all eight returned 200 and dispatched OTP messages.

Applied code fix. backend/lib/auth/otp.ts uses a shared account lock, 60-second issuance cooldown and five-failure, 15-minute lockout. Authentication routes return 429 and retry metadata; frontend/app/Auth/page.tsx displays countdown and lockout timers.

Verification. security-otp.test.ts covers concurrent issuance, cross-purpose cooldown, five wrong guesses, lockout expiry and one-time consumption. The frontend timer is type-checked; browser E2E remains pending.

F-07 Subscription Object Authorization — Critical

Root cause and exploit vector. The supplemental report used two independent accounts in Burp Suite. An attacker token read and changed the victim subscription expiry via GET and PUT /api/subscriptions/[id], without an ownership check.

Applied code fix. backend/app/api/subscriptions/[id]/route.ts checks authentication and persisted userId on GET and PUT; unrelated accounts receive 403. SUPER_ADMIN bypasses ownership only. Purchased subscriptions remain immutable: authorized PUT returns 405, preventing free extensions or status changes. Owners read their records and cancel through the existing refund path.

Verification. security-confirmed-findings.test.ts tests GET/PUT denial for unrelated and unauthenticated users, owner/admin reads, and no mutation for authorized PUT. This closes IDOR without reopening entitlement editing.

F-08 Stored XSS in Homepage JSON-LD — High

Root cause and exploit vector. The supplemental report stored a workspace name/description containing </script><script>...</script> through PUT /api/workspaces/[id]. JSON.stringify emitted literal angle brackets into the homepage script, allowing HTML parser breakout.

Applied code fix. frontend/lib/json-ld.ts serializes JSON and Unicode-escapes <, >, &, U+2028 and U+2029. frontend/app/page.tsx uses serializeJsonLd for the script content. Encoding at the output boundary protects existing stored payloads and preserves the original text when JSON is parsed.

Verification. Four regression cases cover closing script tags, mixed-case tags, HTML comments, Arabic text and Unicode separators. Tests assert no literal HTML-sensitive characters and exact data round-trip. Homepage integration was inspected; live browser retesting remains a deployment check.

F-09 Public Partner Data Disclosure — High

Root cause and exploit vector. Anonymous GET /api/workspaces/[id] returned the complete related Partner record, exposing tax identifiers and contact email. The workspace list had the same response exposure.

Applied code fix. backend/lib/workspaces/public-partner.ts uses an explicit id/brandName allowlist. Both backend/app/api/workspaces/[id]/route.ts and backend/app/api/workspaces/route.ts replace the nested partner record with this public representation. Workspace city remains available; taxNumber, taxId, crNumber, email and phone are excluded.

Verification. Route tests inject sensitive partner fields into database fixtures and assert that detail and list responses contain only the allowed partner fields. A hidden-workspace test confirms anonymous requests still receive 404.

F-10 Administrator Provisioning Through Public Reads — High

Root cause and exploit vector. The supplemental report found GET /api/loyalty-rules called seedLoyaltyRules on an empty table, formerly provisioning admin@coworkingpass.sa with password and returning proposer/approver email addresses.

Applied code fix. backend/app/api/loyalty-rules/route.ts no longer imports or invokes a seed routine. A Prisma field allowlist excludes proposer/approver identities. Empty results return []. The workspace list automatic seed path was also removed. Earlier seed-data.ts hardening already removed default admin creation and requires an existing securely provisioned admin.

Verification. Tests verify empty loyalty and workspace reads never invoke seeding or user creation, and confirm the loyalty query selects only rule fields. Current seed helper was inspected to confirm missing administrators cause an error rather than account provisioning.

3 Quality Assurance Summary

Check	Result
Backend automated unit tests	129 passed across 15 test files; 100% of executed tests passed
Backend TypeScript	Passed: tsc --noEmit
Frontend TypeScript	Passed: tsc --noEmit
PostgreSQL migration and race checks	Pending: database-backed staging validation
Browser end-to-end and production build	Pending

The 129-test result includes the previous 111 tests plus 18 supplemental regression tests. Backend npm test and both npm run typecheck commands passed on 9 November 2026. The security unit tests mock database transactions; they do not prove real PostgreSQL lock behavior or production deployment.

4 Operational Scope

Checkout currently supports wallet-funded settlement only. Card/invoice checkout, ordinary self-service top-ups, and client-calculated pass or points discounts remain blocked until verified provider callbacks and server-side entitlement rules are implemented. OTP lockout is account-bound; no separate trusted-edge IP limiter is included.

5 Deployment and Migration Checklist

Migration status: Migration Script Ready; local PostgreSQL migration testing and production deployment on Neon are pending. The prepared SQL adds Payment, WalletTransaction and CompanyWalletTransaction checks. Inspect historical invalid amounts, apply the Prisma migration to staging, regenerate the client, and verify constraints and concurrency before deploying to Neon. prisma db push alone does not install the custom checks.

Generate a fresh JWT_SECRET of at least 32 characters using a cryptographically secure random generator, store it in the deployment secret manager, rotate any exposed key and revoke affected sessions. Audit and disable any historical default administrator accounts; removing a seed path does not remove accounts already provisioned. Configure strong Super Admin credentials and OTP email delivery. Verify catalog rates and membership plan durations before rollout.

6 Formal Sign-off and Approval

Student declaration: I submit the implementation and local verification evidence for supervisor review, acknowledging the remaining deployment checks.

Student	Supervisor
Anas Saeed Alghamdi Student ID: 444005852 Umm Al-Qura University	Name: _____ Title: _____
Signature: _____ Date: _____	Signature: _____ Date: _____

Supervisor disposition: [ ] Code remediation accepted [ ] Revision required
Production deployment acceptance: [ ] Pending [ ] Accepted after staging verification